

Compliance Oracle: Policy Gap Analysis

Benchmarking Baseline for AI Compliance Mapping Agent Validation

This report provides an analytical breakdown of the provided *Organizational Policy Framework Report*. It maps controls found, gaps identified, and open risks to serve as a ground-truth calibration key for your AI Compliance Mapping Agent.

1. Section-by-Section Compliance Mapping

Policy Section	Controls Found	Gaps Identified	Open Risks
2. InfoSec Policy [src: 4-6]	Access Control Encryption Standards Secure Networking Periodic Assessments	- No defined encryption strength (e.g., AES-256). - No vulnerability management timeline.	Unauthorized data exposure due to weak cryptographic implementations or unpatched edge perimeter flaws.
3. Data Privacy [src: 7-9]	Data Minimization Purpose Limitation Explicit Consent	- Fails to specify consumer data rights (Access, Erasure/DSAR). - No Data Retention or secure disposal schedules.	Regulatory non-compliance penalties (GDPR/DPDPA) from infinite data hoarding and unfulfillable user requests.
4. Risk Management [src: 10-12]	Risk Identification Risk Registers Scheduled Reviews	- Lacks defined risk ownership criteria. - No standardized risk scoring matrices or tolerance thresholds.	Subjective risk tracking, unmitigated high risks, and failure to trigger operational escalation paths.
5. Access Control [src: 13-15]	Least Privilege RBAC & MFA Periodic Access Reviews	- No explicit parameters for privilege revocation timelines. - Excludes session management or logging configurations.	Privilege creep and delayed removal of terminated employee credentials leading to insider threats.
6. Incident Response [src: 16-18]	Immediate Reporting Incident Logging Escalation & Containment	- No explicit service-level timelines (e.g., SLA for critical severity). - Fails to mention regulatory breach notification windows.	Regulatory fines due to delayed statutory breach declarations (e.g., failing the GDPR 72-hour notification rule).
7. Business Continuity [src: 19-21]	BCP Maintenance Disaster Recovery (DR) Simulated Testing	- Omits explicit objective definitions for RTO (Recovery Time) and RPO (Recovery Point). - No mention of backup strategies.	Extended business down-time and irreversible data loss due to undefined target system restoration windows.
	ISO 27001 Alignment Legal & Regulatory Tracking		Contractual default or operational vulnerability due to lack of verified,

Policy Section	Controls Found	Gaps Identified	Open Risks
8. Compliance Policy [src: 23-24]		• Declares "alignment" rather than audited certification. • Does not detail independent third-party audit cadences.	externally validated compliance controls.
10. Audit & Monitoring [src: 27-28]	Continuous Monitoring Internal Auditing	• No log retention, immutability, or SIEM storage metrics. • Lacks auditor structural independence requirements.	Tampering with forensic trails by malicious actors and inability to reconstruct incident root causes.

2. Strategic Systemic Observations for Agent Calibration

To evaluate if your AI Compliance Agent functions at an advanced level, assess whether its output flags these macro-level systemic issues:

- **High-Level Ambiguity:** The document extensively mentions high-level operational concepts ("periodic reviews", "encryption standards") but fundamentally lacks specific quantitative metrics, strict frequencies, or execution owners.
- **Regulatory Blindspots:** While referencing data privacy rules and ISO 27001 [src: 8, 24], it fails to institutionalize mandatory modern baseline mechanisms like Data Protection Impact Assessments (DPIAs), explicit breach notification timelines, or immutable security log repositories.